

MT Keamanan Web - Quiz Pertemuan 5

Metode Pengujian Keamanan Sistem Informasi

1. Apa itu *security testing*

Security testing adalah proses pengujian yang dilakukan untuk mencari tau seberapa aman sebuah sistem informasi dari ancaman atau serangan. Pengujian ini dilakukan bukan setelah sistem terkena masalah, tetapi justru sebelum. Tujuannya supaya celah yang ada bisa ditemukan dan diperbaiki lebih dulu.

Misalnya kita punya aplikasi web akademik, *security testing* akan memastikan apakah data mahasiswa bisa diakses orang lain yang tidak berhak, apakah halaman loginnya gampang dibobol, atau apakah ada konfigurasi server yang keliru. Singkatnya, ini adalah proses untuk "mencari masalah duluan" sebelum orang lain yang menemukannya.

2. Tujuan dari dilakukannya pengujian keamanan

Tujuan dari pengujian keamanan adalah menemukan kerentanan sistem sebelum dieksploitasi. Tapi selain itu, pengujian ini juga membantu tim pengembang mengetahui bagian mana yang perlu diperbaiki, dan memastikan bahwa sistem sudah memenuhi standar keamanan yang berlaku.

Di lingkungan institusi seperti universitas atau perusahaan, *security testing* juga penting untuk membuktikan bahwa sistem yang digunakan sudah patuh terhadap regulasi atau kebijakan keamanan tertentu, bukan cuma aman di atas kertas.

3. Perbandingan metode pengujian keamanan

Aspek	Vulnerability Assessment	Penetration Testing	Security Audit
Tujuan	Menemukan dan mencatat semua celah keamanan yang ada di sistem	Membuktikan apakah celah yang ditemukan bisa benar-benar dieksploitasi	Menilai apakah sistem sudah sesuai dengan standar dan kebijakan keamanan
Cara kerja	Pakai tools otomatis seperti Nessus atau OpenVAS untuk scanning seluruh sistem	Penguji secara aktif mencoba menyerang sistem, mensimulasikan serangan nyata	Review dokumen, kebijakan, konfigurasi, dan prosedur keamanan yang diterapkan
Hasil	Daftar kerentanan beserta level risikonya (low, medium, high, critical)	Laporan celah yang berhasil dieksploitasi beserta dampak dan rekomendasinya	Laporan kepatuhan terhadap standar seperti ISO 27001
Sifat	Pasif, hanya mendeteksi	Aktif, benar-benar menyerang secara terkontrol	Evaluatif, fokus pada kesesuaian kebijakan
Contoh tools	Nessus, OpenVAS, Qualys	Metasploit, Burp Suite	Checklist audit, wawancara, review konfigurasi

4. Dari kasus penipuan yang pernah dibahas pada pertemuan 3 (penipuan apk/malware)
 - a) Metode pengujian apa yang bisa digunakan untuk mendeteksi masalah tersebut
Untuk kasus seperti modus APK Kurir, metode yang paling sesuai adalah *Penetration Testing*, terutama yang berfokus pada analisis aplikasi mobile. Bisa dikombinasikan dengan *Vulnerability Assessment* di awal sebagai langkah pemindaian awal
 - b) Mengapa metode tersebut cocok
Dari kasus APK Kurir, ancaman utamanya adalah *spyware* yang bisa membaca SMS dan mencuri OTP. Scanning otomatis tidak cukup untuk mendeteksi ini karena *spyware* memang dirancang untuk menghindari pemindaian standar.
Dengan *penetration testing*, penguji bisa melakukan *reverse engineering* terhadap file APK, menganalisis permission yang diminta, dan menjalankannya di *sandbox* untuk melihat perilakunya langsung. Hasilnya bukan cuma tahu bahwa aplikasi itu berbahaya, tapi juga tahu persis cara kerjanya.
5. Mengamankan aplikasi mahasiswa berbasis website
 - a) Metode pengujian dan langkah-langkahnya
Pendekatan yang akan saya gunakan adalah kombinasi *Vulnerability Assessment* di awal, lalu dilanjutkan dengan *Penetration Testing*. Dua tahap ini penting karena saling melengkapi yang satu memberi gambaran besar, yang satunya menguji lebih dalam.
 - Langkah pertama adalah reconnaissance, yaitu mengumpulkan informasi dasar soal aplikasi: teknologi apa yang dipakai, bagaimana struktur URL-nya, fitur apa saja yang ada seperti login, upload file, atau halaman data pribadi mahasiswa
 - Setelah itu dilanjutkan dengan *vulnerability scanning* menggunakan tools seperti OWASP ZAP atau Nikto. Di sini kita bisa mendeteksi celah-celah umum seperti SQL Injection, XSS, atau *misconfiguration* pada server
 - Dari hasil scanning, baru masuk ke *penetration testing* manual, menguji secara aktif apakah celah yang ditemukan memang bisa dieksploitasi. Misalnya, apakah form login rentan *brute force*, apakah fitur upload bisa dipakai untuk mengunggah file berbahaya, atau apakah *session* pengguna bisa dibajak
 - Terakhir, semua temuan didokumentasikan dalam laporan yang berisi detail celah, tingkat risiko, dan rekomendasi perbaikan untuk tim developer
 - b) Lebih penting mana, *vulnerability assessment* atau *penetration testing*
Menurut saya, *vulnerability assessment* lebih penting sebagai langkah pertama. Kita perlu tahu dulu ada celah apa saja sebelum memutuskan mana yang perlu diuji lebih dalam. VA juga lebih efisien karena prosesnya otomatis dan bisa mencakup seluruh sistem sekaligus, cocok untuk universitas yang tim keamanannya terbatas.
Penetration testing tetap dibutuhkan, tapi akan lebih efektif kalau dilakukan setelah VA selesai dan hasilnya sudah sebagian diperbaiki.